

In this blog we discuss today's cost of being hit by a ransomware attack and how investing in preemptive threat intelligence tools can reduce the risk of a ransomware attack and the associated costs.

Key Takeaways

- Global ransomware damage costs are projected to reach \$74 billion in 2026 - a 30% increase from 2025
- The average total cost of a ransomware attack is now \$5.08 million, but the ransom payment itself accounts for only ~15% of that figure
- The biggest cost drivers are operational downtime, system recovery, legal fees, regulatory fines, and lost business - not the ransom
- Modern ransomware groups exfiltrate data before encrypting it, meaning paying the ransom or restoring from backup does not undo the breach
- Organizations that take a preemptive approach - reducing attack surface exposure, monitoring the dark web for compromised credentials, and closing gaps before they are exploited - avoid the vast majority of these costs entirely
- By the time ransomware executes, the damage is already done. The encryption is just the bill arriving.

The fact of the matter is, most organizations underestimate ransomware costs. When security leaders think "ransomware attack," they picture ransom demands. The reality? Those payments represent pocket change compared to the total devastation.

In 2026, the true cost of a ransomware attack is continuing to increase. And the organizations that understand the full picture are the ones rewriting their strategy to avoid becoming a victim in the first place.

The Numbers Are Getting Worse

Global ransomware damage costs are projected to reach \$74 billion in 2026 - a 30% increase from \$57 billion in 2025 - according to Cybersecurity Ventures. That works out to roughly \$203 million lost every single day, \$8.5 million every hour, and \$2,400 every second.

At an individual organization level, IBM's data shows the average total cost of a ransomware breach now sits at \$5.08 million - a figure that has risen 9% since 2021 and a staggering 574% since 2019, when the average stood at \$761,000. In the US specifically, total ransomware breach costs average \$10.22 million.

These numbers are moving in one direction. And the organizations still treating ransomware as an "if it happens, we'll deal with it" problem are increasingly on the wrong side of history.

The Iceberg Beneath the Ransom

The ransom payment itself represents, on average, just 15% of the total cost of an attack. The rest is largely invisible until it hits - operational paralysis, legal bills, regulatory fines, and a reputational hangover that can last years.

Here is where the money actually goes:

Operational Downtime

This is consistently the most expensive component. Organizations face an average of 24 days of downtime following a ransomware attack. For manufacturers, that translates to an estimated \$1.9 million per day in losses. For healthcare organizations, around \$900,000 per day. Research from Acronis puts total downtime costs at up to 50 times the ransom demand itself.

Detection and Containment

Before you can even begin to recover, you first have to understand what happened, where the attackers got in, what they accessed, and what they took. IBM data puts detection and containment costs at an average of \$1.47 million per incident. This involves forensic investigators, incident response teams, and the internal resources consumed by weeks of investigation.

System Recovery and Rebuilding

Restoring systems from backup is rarely as clean as organizations hope. Backups may be incomplete, corrupted, or themselves compromised - attackers often specifically target backup infrastructure. The average recovery cost (excluding the ransom) reached \$2.73 million in recent data, nearly \$1 million higher than the year before.

Regulatory Fines and Legal Costs

If ransomware results in a data breach - and today, with double extortion tactics standard practice among ransomware groups, it almost always does - organizations face potential fines under GDPR, HIPAA, or other applicable regulations. Notification obligations add further cost: legal fees, regulatory engagement, and mandatory breach notifications to affected individuals. IBM estimates notification costs alone average \$390,000 per incident.

Post-Breach Response

Once the dust settles, organizations must harden systems, implement new controls, and demonstrate to regulators and customers that the vulnerabilities have been addressed. This post-breach response phase adds an average of \$1.2 million to the total bill.

Lost Business and Revenue

Ransomware attacks don't just halt operations - they erode customer trust, damage contracts, and in some cases result in permanent customer churn. Lost business costs average \$1.38 million per incident, but for organizations in sectors where trust is

everything - financial services, healthcare, critical infrastructure - the long-tail revenue impact can be far greater.

Reputational Damage

Harder to quantify but impossible to ignore. Media coverage of a ransomware attack, particularly one involving data theft and public disclosure on a leak site, changes how customers, partners, investors, and regulators see an organization. Brand repair takes years and significant investment.

Cyber Insurance

Cyber insurance can offset some costs - but premiums have risen sharply alongside the frequency and severity of attacks. And increasingly, insurers are tightening coverage terms, excluding certain types of attacks, or requiring organizations to demonstrate security hygiene standards before claims are honoured.

Hidden Costs Most Organizations Overlook

- Beyond the categories above, there are costs that rarely make it into the post-incident analysis:
- Supply chain disruption - if your systems go down, your suppliers and customers feel it too, and third-party claims can follow
- Executive and board time - weeks of senior leadership consumed by crisis management rather than running the business
- Recruitment and retention impact - a public breach can damage employer reputation and make it harder to attract security talent

- Intellectual property theft - sensitive R&D, strategic plans, or competitive data exfiltrated before encryption may never be recovered
- Increased borrowing costs - some organizations face credit rating impacts following major incidents
- Re-ransom risk - paying once marks you as a payer; many organizations that pay are targeted again within 12 months

Why Recovery Is Never Enough

There is a persistent myth in ransomware response: that if you have good backups and a solid incident response plan, you can absorb an attack and bounce back. The data suggests otherwise.

Modern ransomware groups operate like professional businesses. Initial access brokers sell footholds into compromised organizations. Affiliates deploy payloads. Data exfiltration happens before encryption - giving attackers leverage through double and triple extortion even if you restore from backup. In many cases, threat actors dwell inside environments for days or weeks before triggering the encryption stage, collecting data and establishing persistence throughout.

By the time ransomware executes, the damage is already done. The encryption is just the bill arriving.

Recovering quickly reduces downtime. But it does not address the data that has already been stolen. It does not address the regulatory consequences that follow a breach. It does not address the reputational harm of appearing on a ransomware leak site. And it does nothing to close the vulnerability, misconfiguration, or

exposed credentials that let the attackers in - leaving the door open for the next group.

Preemptive Defense

The Only Way to Truly Win Is to Not Get Hit

Given the scale and complexity of costs outlined above, the economics of ransomware prevention versus recovery are clear. Every pound spent on preemptive defense is a fraction of the cost of a single incident.

But this isn't just a financial argument. It's an architectural one.

Ransomware doesn't begin with encryption - it begins with exposure. Long before a ransom note appears on screen, threat actors are scanning internet-facing assets, probing for misconfigured services, purchasing stolen credentials from infostealers, and identifying the weakest entry points into an organization's environment. Ransomware groups are running automated, industrial-scale reconnaissance operations, and any organization with unaddressed exposure is, to them, a viable target.

Stopping ransomware means addressing that exposure before attackers can exploit it. That requires:

Continuous Attack Surface Management (ASM) - understanding every internet-facing asset across your

infrastructure, subsidiaries, and cloud environments, including the assets you might not know you own. Shadow IT, forgotten subdomains, legacy test environments - these are exactly what ransomware groups look for. If you don't know it exists, you can't secure it.

Dark Web Monitoring - credential theft through phishing and infostealers is one of the most common ransomware entry vectors. Monitoring the dark web for compromised credentials tied to your organization allows you to detect and remediate access before it is weaponised.

Threat Intelligence - ransomware groups have known TTPs. They scan for specific vulnerabilities, target specific technologies, and operate with documented playbooks. Threat intelligence that tracks active ransomware group behaviour enables organizations to proactively patch and remediate the exact vulnerabilities those groups are targeting - before an attack is launched.

Rapid Remediation - visibility without action is just surveillance. The window between a vulnerability being disclosed and ransomware groups scanning for it can be measured in hours. Prioritising remediation based on real-world threat actor activity rather than CVSS scores alone is the difference between closing the door before the attacker arrives and doing so after.

The goal is not faster recovery. It is preventing attackers from reaching the encryption stage at all.

From Reactive to Preemptive

Organizations that continue to treat ransomware as an incident response challenge will keep paying - in ransom, in downtime, in

legal costs, and in lost trust. The \$74 billion global bill for 2026 is the aggregate cost of that reactive posture.

The organizations breaking out of that cycle are the ones shifting upstream in the attack lifecycle. They are identifying their exposure before attackers do. They are monitoring for early warning signs - suspicious access patterns, compromised credentials surfacing on dark web forums, ransomware groups targeting technologies they use. They are making themselves harder to attack, not just faster to recover.

Because by the time ransomware hits, no matter how prepared your response is, you are already counting the cost.

Bio

Luke Donovan is Head of Threat intelligence at Searchlight Cyber. Luke's background is in military intelligence and security within the British Army, where he served in Afghanistan, Libya, and the Middle East, supporting counter-terrorism and narcotics efforts. He later transitioned to the cyber sector and now leads our expert team of threat intelligence analysts at Searchlight.



Author

Luke Donovan

HEAD OF THREAT INTELLIGENCE AT
SEARCHLIGHT CYBER

Luke Donovan is Head of Threat intelligence at Searchlight Cyber. Luke's background is in military intelligence and security within the British Army, where he served in Afghanistan, Libya, and the Middle East, supporting counter-terrorism and narcotics efforts. He later transitioned to the cyber sector and now leads our expert team of threat intelligence analysts at Searchlight.